

CIS Controls

1. Overview

The CIS Controls (formerly known as the SANS Top 20, now maintained by the **Center for Internet Security**) are a **prescriptive, prioritized set of specific technical and organizational safeguards** designed to defend against the most common and impactful real-world cyberattacks. Where NIST CSF (see the companion guide) provides a high-level organizing structure and vocabulary, CIS Controls sit at the opposite end of the specificity spectrum — a concrete, actionable list of exactly what to actually implement, ranked by priority and grounded directly in observed attack patterns.

Property	Detail
Type	Voluntary, prescriptive technical control framework
Maintained by	Center for Internet Security (CIS)
Current major version	CIS Controls v8.1 (updated from v8, which itself succeeded v7.1's "20 Controls" structure)
Structure	18 Controls, broken into specific numbered Safeguards
Who uses it	Any organization; particularly popular for its practicality and prioritization guidance for resource-constrained security teams

2. Why CIS Controls Exist — Attack-Informed Prioritization

The defining design principle behind CIS Controls, distinguishing them from broader compliance checklists, is that they are explicitly derived from and prioritized according to **real-world attack data** — analysis of how actual breaches and incidents occur — rather than being built from first-principles risk theory alone. The goal is to answer a very practical question: *given limited security resources, what should an organization implement first to have the greatest actual impact on reducing real attack risk?*

3. The 18 CIS Controls (v8.1)

1. Inventory and Control of Enterprise Assets
2. Inventory and Control of Software Assets

3. Data Protection
4. Secure Configuration of Enterprise Assets and Software
5. Account Management
6. Access Control Management
7. Continuous Vulnerability Management
8. Audit Log Management
9. Email and Web Browser Protections
10. Malware Defenses
11. Data Recovery
12. Network Infrastructure Management
13. Network Monitoring and Defense
14. Security Awareness and Skills Training
15. Service Provider Management
16. Application Software Security
17. Incident Response Management
18. Penetration Testing

Note the deliberate ordering: the first several controls (Asset Inventory, Software Inventory, Data Protection, Secure Configuration, Account Management) address foundational visibility and hygiene — you genuinely cannot secure what you don't know you have, which is exactly why "know your assets" sits at Controls 1 and 2 rather than being treated as an afterthought behind more sophisticated-sounding controls like penetration testing (Control 18).

4. Implementation Groups (IGs) — Built-In Prioritization for Resource-Constrained Organizations

This is CIS Controls' single most distinctive and practically valuable feature relative to most other frameworks in this series: each of the specific numbered **Safeguards** underneath the 18 Controls is explicitly tagged with an **Implementation Group**, giving organizations a genuinely usable starting point based on their actual size and risk profile rather than facing an undifferentiated wall of requirements.

Implementation Group	Target Organization Profile	Safeguard Count (approx.)
IG1	Small/resource-limited organizations with limited IT/security expertise; focused on essential cyber hygiene	~56 foundational safeguards

Implementation Group	Target Organization Profile	Safeguard Count (approx.)
IG2	Organizations with dedicated IT/security staff managing more complex, sensitive data across multiple departments	Adds further safeguards on top of IG1 (~130 cumulative)
IG3	Larger, more sophisticated organizations facing significant risk, often in regulated or high-value-target sectors, with mature security operations	Adds the remaining, most advanced safeguards (~150+ cumulative)

Every organization, regardless of size, is expected to be able to achieve **IG1** — CIS explicitly frames IG1 as "essential cyber hygiene," the minimum standard of care every organization should meet — with IG2 and IG3 representing progressively more sophisticated, resource-intensive additions layered on top, not entirely separate control sets.

5. Safeguards — The Actual Granular Requirements

Beneath each of the 18 Controls sit specific, individually numbered **Safeguards** — concrete, actionable statements (e.g., under Control 5, Account Management: "Establish and maintain an inventory of accounts," "Use unique passwords," "Disable dormant accounts," "Restrict administrator privileges to dedicated administrator accounts"). This granularity is what makes CIS Controls directly implementable by a technical team without requiring the same degree of organization-specific risk-assessment translation that NIST CSF's more abstract subcategories or ISO 27001's risk-based Annex A selection process require.

6. CIS Benchmarks — A Related but Distinct Resource

Worth distinguishing clearly: **CIS Benchmarks** are a separate, complementary set of resources from CIS — detailed, product-specific secure configuration guides (e.g., a CIS Benchmark for a specific operating system, cloud platform, or application) providing exact, step-by-step hardening recommendations. Where the 18 CIS Controls describe *what categories of safeguard* an organization needs, CIS Benchmarks provide the *specific technical configuration steps* to actually harden a given product or platform — directly

supporting Control 4 (Secure Configuration) in particular, but relevant across the whole control set wherever specific technology hardening is required.

7. Relationship to Other Frameworks in This Series

- **NIST CSF** — CIS Controls map cleanly onto NIST CSF's functions (each CIS Control and Safeguard can be associated with one or more of Govern/Identify/Protect/Detect/Respond/Recover), making the two frameworks natural complements: CSF for the high-level risk narrative and governance structure, CIS Controls for the specific technical implementation detail underneath it.
- **ISO 27001** — CIS Controls can serve as a highly practical, attack-informed source of specific technical controls when populating an ISO 27001 Statement of Applicability, particularly for the "Technological controls" theme of Annex A.
- **PCI DSS** — significant overlap exists between CIS Controls' foundational safeguards (asset inventory, secure configuration, access control, vulnerability management, logging) and PCI DSS's twelve requirements, though PCI DSS remains specifically scoped to cardholder data environments while CIS Controls apply organization-wide.
- CIS itself publishes explicit mapping documents cross-referencing the Controls against NIST CSF, NIST SP 800-53, ISO 27001, and other major frameworks — reflecting that CIS Controls are commonly used as an implementation layer supporting compliance with several other frameworks simultaneously, rather than existing in isolation.

8. Why Organizations Adopt CIS Controls

- **Practicality and prioritization** — the Implementation Group structure gives even small, resource-constrained organizations a genuinely achievable, clearly bounded starting point, rather than an undifferentiated list that implicitly assumes enterprise-scale resources.
- **Attack-grounded relevance** — controls are prioritized based on demonstrated real-world attack patterns, giving confidence that implementation effort is being spent where it actually reduces risk most.
- **Concrete, implementable detail** — technical teams can act directly on specific Safeguards without needing to first translate an abstract risk

category into a concrete technical requirement themselves.

- **Free and publicly available** — unlike some standards bodies, CIS publishes the Controls and supporting resources (including CIS Benchmarks) freely, lowering the barrier to adoption significantly.

9. Common Real-World Adoption Gaps

- Attempting to implement IG2 or IG3 safeguards before genuinely achieving complete IG1 coverage — undermining the framework's own explicit prioritization logic (foundational hygiene first).
- Treating asset and software inventory (Controls 1–2) as a one-time project rather than a continuously maintained, accurate, living record — a common root cause of downstream control failures across nearly every other Control, since you cannot secure, patch, or monitor an asset you don't know exists.
- Adopting CIS Benchmarks for hardening without corresponding change management or configuration drift monitoring, allowing hardened configurations to silently decay over time.
- Selecting an Implementation Group based on organizational aspiration rather than an honest assessment of actual current resources and risk profile, leading to partial, inconsistent implementation across a broader safeguard set than the organization can genuinely sustain.

10. Summary

CIS Controls provide a prescriptive, attack-data-informed set of 18 top-level controls and specific underlying Safeguards, distinguished by their built-in Implementation Group prioritization — making them one of the most immediately actionable frameworks covered in this series, particularly for organizations without the resources to conduct an extensive independent risk assessment from first principles. Their concrete, technically specific nature makes them a natural implementation layer beneath higher-level frameworks like NIST CSF's governance structure or ISO 27001's risk-based Annex A, and their explicit "start with IG1 foundational hygiene" prioritization directly embodies the broader principle, echoed throughout this series, that basic, consistently maintained fundamentals reduce more real-world risk than sophisticated controls layered on top of a shaky foundation.